

SISTEMA DE GESTÃO DE SEGURANÇA — SGS

ARQUITETURA E FLUXO OPERACIONAL

SaaS multi-tenant de SST · 54 módulos · NestJS 11 + Next.js 16 + PostgreSQL/RLS · Diagrama conferido contra o código-fonte

1 ACESSO

- **Web** — Next.js 16 / Vercel
- **Mobile** — responsivo, campo
- **PWA** — offline-first, service worker
- **Público** — QR, sem login

2 AUTENTICAÇÃO

- **CPF + senha** — Argon2id
- **MFA/TOTP** **OBRIGATÓRIO** para ADMIN em produção
- **JWT** 15min + refresh 30d httpOnly
- Anti-brute force por IP e conta
- Pwned Password + Turnstile

3 AUTORIZAÇÃO

- **RBAC** — permissões granulares
- Perfis e templates de papel
- Escopo por obra/site
- Cache de permissões (Redis)

4 ISOLAMENTO MULTI-TENANT

- **Camada 1** — app filtra por empresa
- **Camada 2** — RLS no PostgreSQL
- Header x-company-id + AsyncLocalStorage
- SET LOCAL app.current_company_id

Fail-closed: sem contexto de empresa a consulta retorna zero linhas — nunca “todas”. Falha na aplicação não vaza dados: o banco barra.

5 CADASTRO BASE

- Empresas (tenants) e Obras/Sites
- Colaboradores · Perfis · Funções
- Máquinas · Ferramentas · EPIs
- Contratos · Políticas do tenant

16 DADOS E STORAGE

- **Neon PostgreSQL** — RLS, TypeORM particionamento por data
- **Redis (Upstash)** — 3 conexões: auth · cache · queue
- **Backblaze B2** — PDFs, anexos, vídeos
- Réplica de leitura

18 CONTINUIDADE

- Backup DR diário por tenant
- Storage DR secundário
- Restore + scanner de integridade
- Heartbeat do worker

6 · MÓDULOS DE SST — DOCUMENTOS GOVERNADOS

APR

Análise Preliminar de Risco

- Matriz P × S (5×5)
- Aprovação multinível
- Evidências fotográficas
- Versionamento

PT

Permissão de Trabalho

- NR-33 espaço confinado
- NR-35 altura
- Medições atmosféricas
- Vigia · plano de resgate

DDS

Diálogo Diário de Segurança

- Temas e palestras
- Assinatura por convite
- Foto de equipe

RDO

Registro Diário de Obra

- Serviços executados
- Efetivo e clima
- Fotos por atividade

ARR / DID

Risco de rotina · Identificação

- Análise de rotina
- Alinhamento inicial

CAT / NC

Acidente · Não Conformidade

- Comunicação de acidente
- Investigação e causa
- Ações corretivas

CHECKLISTS

Inspecões e auditorias

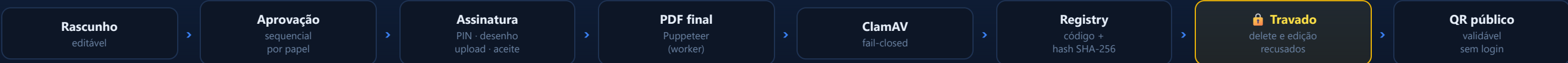
- Modelos por categoria
- Execução em campo
- Auditorias + plano de ação

PESSOAS

Saúde e capacitação

- Treinamentos + validade
- Exames (ASO/PCMSO)
- Entrega de EPI + CA

7 PIPELINE DE GOVERNANÇA DOCUMENTAL — o coração do produto



Trava técnica, não convenção: após o PDF final, a exclusão é recusada pelo sistema — não depende de disciplina do usuário nem de perfil. Correção exige nova versão; a anterior permanece registrada. · **Soft delete sempre** (deleted_at), nunca hard delete.

8 PROVA DE ASSINATURA

- **PIN (hmac)** **VERIFICADO** PBKDF2/HMAC-SHA256 no servidor
- **Desenhada** — imagem
- **Upload** — imagem
- **Aceite** — registro de ato

Não é ICP-Brasil. O sistema declara not_legal_strong. O rótulo impresso no PDF corresponde à prova real coletada — rótulos legados enganosos foram removidos.

9 TRILHA E AUDITORIA

- **Trilha forense** — emissão, assinatura, cancelamento, expiração
- Acesso a **vídeo** registrado
- **Audit log** particionado
- Dossiê do trabalhador

10 SOPHIE — IA

- Assistente SST + visão
- Consulta APR/PT/riscos
- **Consentimento LGPD** versionado
- Sanitização de PII

Sem consentimento ativo, o acesso é **bloqueado** (fail-closed).

11 DASHBOARD

- KPIs e score SST
- Fila de pendências
- Mapa de risco
- Cache Redis + snapshots

12 PROCESSAMENTO ASSÍNCRONO — 13 filas BullMQ · worker em processo separado (2ª VPS)

- **mail** + DLQ
- **document-import** + DLQ
- **expiry-notifications**
- **tenant-backup**
- **business-metrics-refresh**
- **pdf-generation** + DLQ
- **document-retention**
- **sla-escalation**
- **dashboard-revalidate**
- **ai-recovery**

As 3 **DLQ** (dead-letter) recebem o que estourou retry — é onde olhar quando “o e-mail não chegou” ou “o PDF não gerou”. Bull Board em /admin/queues.

19 RELATÓRIOS

- Relatórios PDF (Puppeteer)
- Relatório fotográfico
- Bundle semanal por módulo
- Exportação Excel

20 DOSSIÊS

- Dossiê do trabalhador
- Linha do tempo operacional
- Status de conformidade
- Código público de acesso

21 OPERAÇÃO

- Atividades · Ordens de serviço
- Riscos · Mapa de risco
- Despesas e adiantamentos
- Calendário **interno** · Tarefas

22 ENTRADA DE DADOS

- Importação de documentos
- Parser Word/Excel
- Anexos de vídeo governados
- Notificações + push

13 VALIDAÇÃO PÚBLICA POR QR

- Fiscal aponta a câmera no PDF
- Token **HMAC assinado** na URL
- Confere contra o registry
- Retorna: autenticidade, emissor, data e hash

Diferencial do produto: qualquer pessoa valida um documento **sem login e sem conta**. Payload mínimo por design (LGPD) — confirma sem expor conteúdo.

14 LGPD

- **CPF e dados médicos** cifrados AES-256-GCM · busca por hash
- Consentimento event-sourced
- **Direito de exclusão** (Art. 18)
- Retenção automatizada
- Registro de subprocessadores

Tensão resolvida: exclusão LGPD × obrigação de guardar documento de SST → o titular é **anonimizado**, o documento permanece.

15 SEGURANÇA

- **ClamAV** em todo upload **FAIL-CLOSED**
- Rate limit distribuído (Redis)
- CSRF · Helmet · CSP · HSTS
- Admin com IP allowlist
- Idempotency-key

17 INTEGRAÇÕES REAIS

- **OpenAI / NVIDIA** — Sophie
- **Resend / SMTP** — e-mail
- **ClamAV** — antivírus
- **Sentry · OpenTelemetry**
- **Cloudflare Turnstile**

Não existem hoje: eSocial, Power BI e assinatura ICP-Brasil. O calendário é **interno** (agrega eventos do próprio banco), sem API do Google.

23 OBSERVABILIDADE

- Winston · OpenTelemetry
- Sentry · New Relic
- Health checks e SLO
- Auditoria de segurança

POR QUE ESTE DIAGRAMA É CONFIÁVEL

Cada afirmação foi conferida **contra o código-fonte**, não contra material anterior. O diagrama antigo listava **eSocial**, **Power BI** e **“Assinatura Digital”** — nenhum existe no sistema — e omitia PT, RDO, CAT, NC, Sophie, o isolamento por RLS e a validação por QR. Aqui, integração declarada é integração que roda: **o que não existe está explicitamente marcado como inexistente** (bloco 17). Um fluxograma que promete o que o produto não entrega vira passivo em auditoria e em venda.

LEGENDA

- VERIFICADO** prova checada pelo servidor
- OBRIGATÓRIO** imposto em produção
- FAIL-CLOSED** na dúvida, bloqueia
- documento governado
- plataforma / infraestrutura
- conformidade e validação